CS670 · CRYPTOGRAPHIC TECHNIQUES FOR PRIVACY PRESERVATION · IIT KANPUR

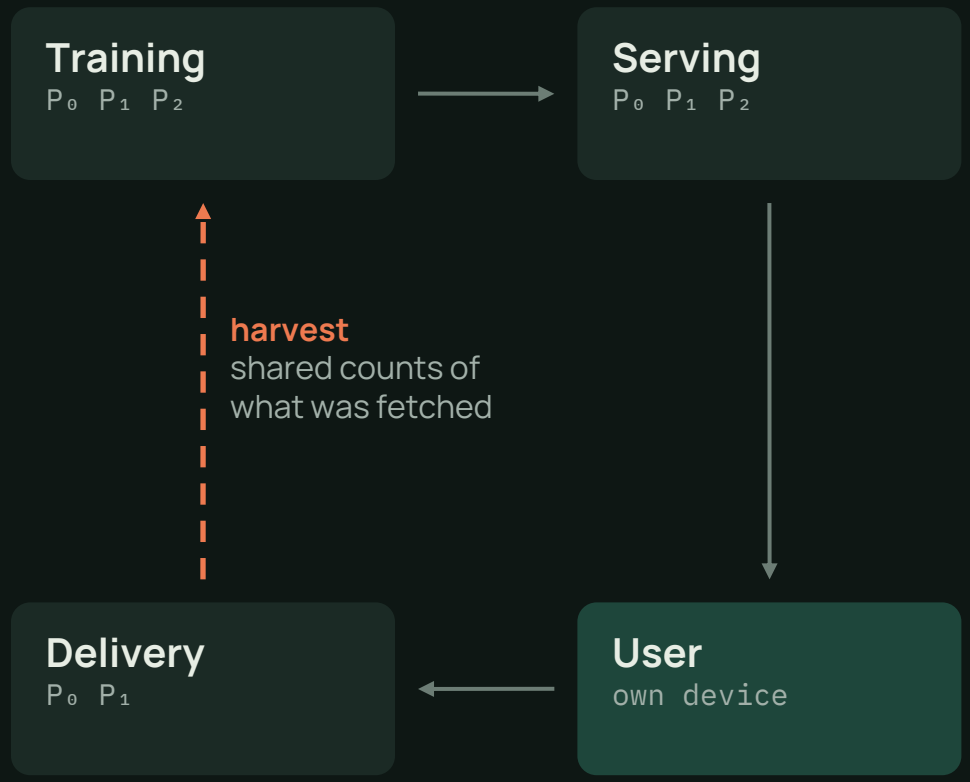
OblivRec

Private training and private delivery for recommendation

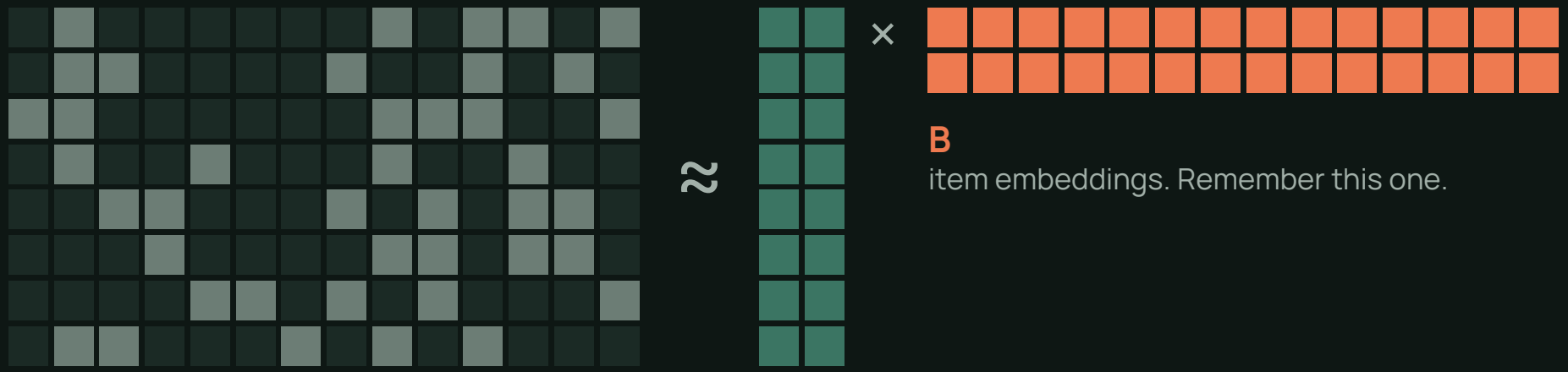
Nudge's three-server training composed with Pirsona's private retrieval, and measured: what the composition costs, and what it leaks.

Shravan Agrawal 230984
Shrasti Dwivedi 230982
Mainak Sarkar 230619

Final presentation · November 2026



What a recommender learns about you



U
ratings, users × items

A
users, secret

B
item embeddings. Remember this one.

Can a service recommend things to you, and deliver them, without learning what you rated, what it recommended, or what you opened?

Two papers, two halves

Collection ratings leave the user → **Training** the model is fitted → **Serving** scores are computed → **Delivery** the item is fetched

NUDGE · USENIX SECURITY 2026

three servers, power iteration on secret shares

stops at the scores

PIRSONA · POPETS 2021

private retrieval for delivery, and the harvest that feeds training, with four-party Boolean training

“relies on other means (e.g., Apple’s private relay, Tor, or cryptographic private information retrieval) to let users fetch data items in a private way.”

Nudge, on what it does not do

What we built

Nudge’s private training, composed with Pirsona’s private delivery, and measured.

WRITTEN	Every protocol in C++17, from the papers. No cryptographic library.
CHECKED	18 test binaries, also run in a hardened build with undefined-behaviour traps and bounds checks.
REPRODUCIBLE	One command, `mingw32-make reproduce`, rebuilds every figure from committed data.

Private training

$$x = x_0 + x_1 + x_2$$

P_0
holds x_0, x_1

P_1
holds x_1, x_2

P_2
holds x_2, x_0

One server sees two uniformly random pieces. Any two can reconstruct, so we assume at most one is compromised.

```
for each of 16 components
  v ← random start
  repeat 10 times
    w ← U · v                          1 round
    v ← transpose(U) · w               1 round
    v ← Trunc(v)                       3 rounds
    v ← SetOrthogonal(v, B)      local, then Trunc
    v ← Normalize(v)                   Trunc inside
  open v as the next row of B    public by design
```

Matrix-vector products cost one round each, whatever the size of U. Truncation and normalisation take most of the rounds.

Private delivery

01
Servers
score shares ⟦a⟧ · B, computed locally, no rounds

→

02
User
adds the shares and picks the top 10 on the device

→

03
User to P_0, P_1
one short key per server, per fetch

→

04
P_0 and P_1
each expands its key over all 2,048 records

227 B

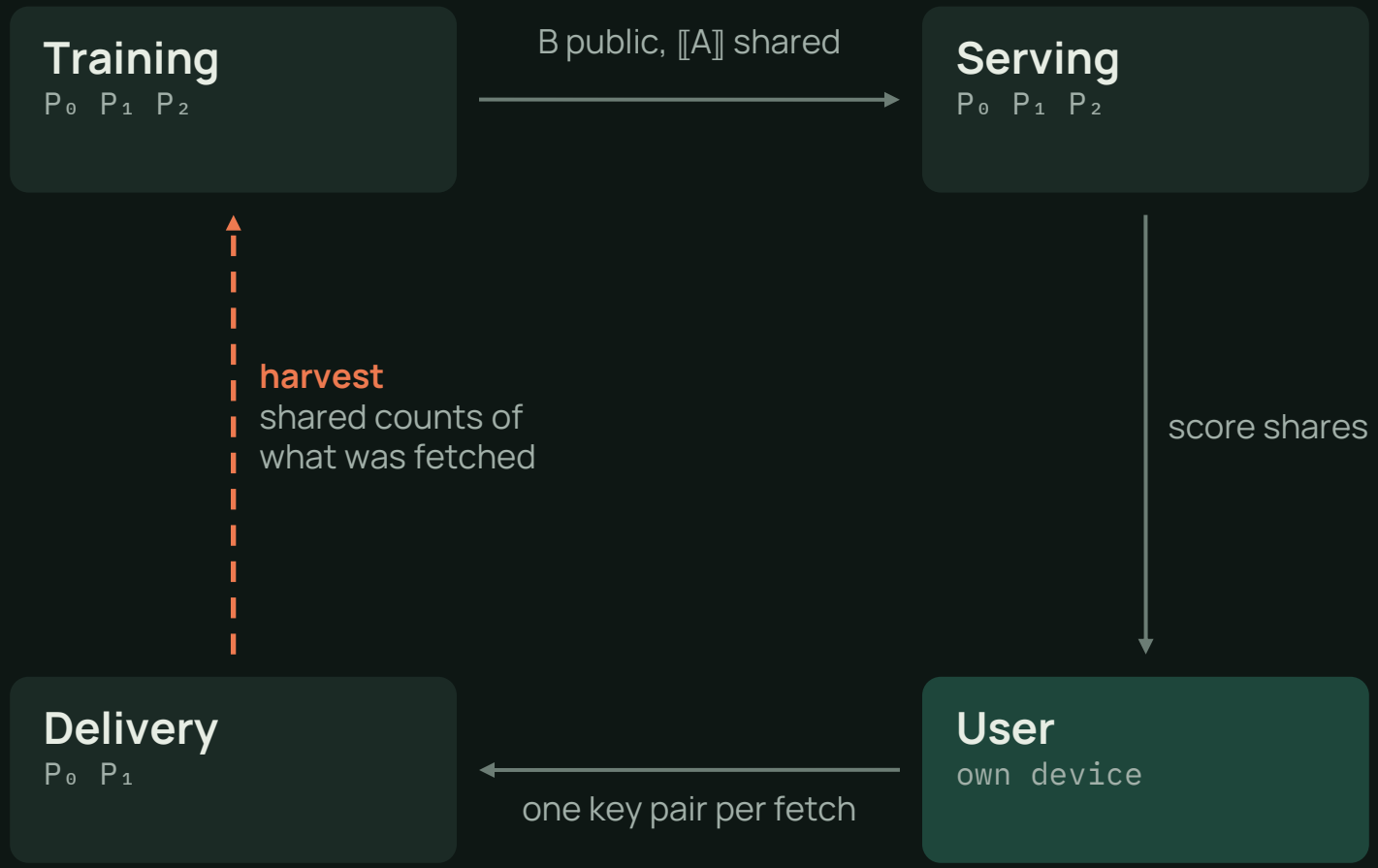
the key each server receives, for a 2,048-record catalogue

16,384 B

the naive one-hot query it replaces

Each key on its own is pseudorandom. The difference of the two answers is the record, and neither server learns which one it was.

Closing the loop



WHAT RUNS TODAY

The harvest, its conversion and the weight check are built and tested. A test drives real private fetches through them into the training code.

The running servers do not yet retrain from harvested counts. Every model in this talk was trained on ratings read from disk.

Cost: one round per training refresh to convert, one round per query to check the weight.

It runs end to end

```
$ demo --user 42 --k 10 \
    --a A_private_fss_b128_ell10.bin --b B_private_fss_b128_ell10.bin

rank item   score (2t-scaled)      title (fetched privately)
0    0      3985510293721          Toy Story (1995)
1    94     3253835172460          Aladdin (1992)
2    172    3003783912317          Princess Bride, The (1987)
3    285    2832029832122          English Patient, The (1996)
4    236    2784941524260          Jerry Maguire (1996)
5    70     2682062760624          Lion King, The (1994)
6    203    2626050118158          Back to the Future (1985)
7    14     2564579331556          Mr. Holland's Opus (1995)
8    317    2432749438261          Schindler's List (1993)
9    116    2292504447885          Rock, The (1996)

ranking agrees with model/out/top10_u42_private_fss_b128_ell10.txt on all 10
positions, in order.
All 10 records fetched privately and verified byte-exact
against a cleartext lookup. Each fetch cost one 227-byte DPF key
per server against a 2048-entry domain.
```

Real output of the demo, captured from the program, not retyped. Model: spec-faithful training, 128-bit ring, 10 iterations.

10 of 10

ranking positions match an independent reference

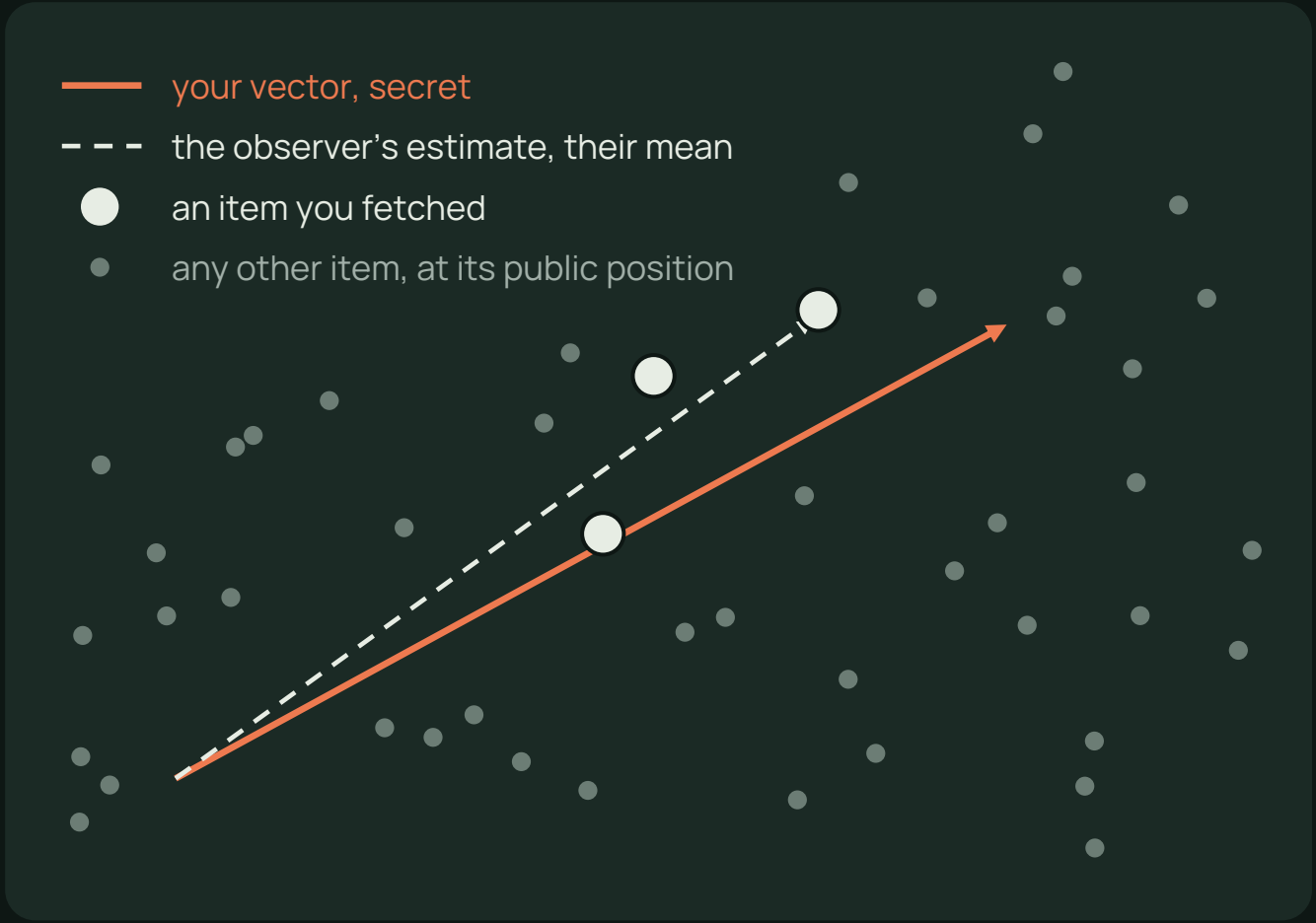
byte-exact

every fetched record, against a cleartext lookup

no leak

the model was trained with the normaliser that reveals nothing

A fetch is a projection



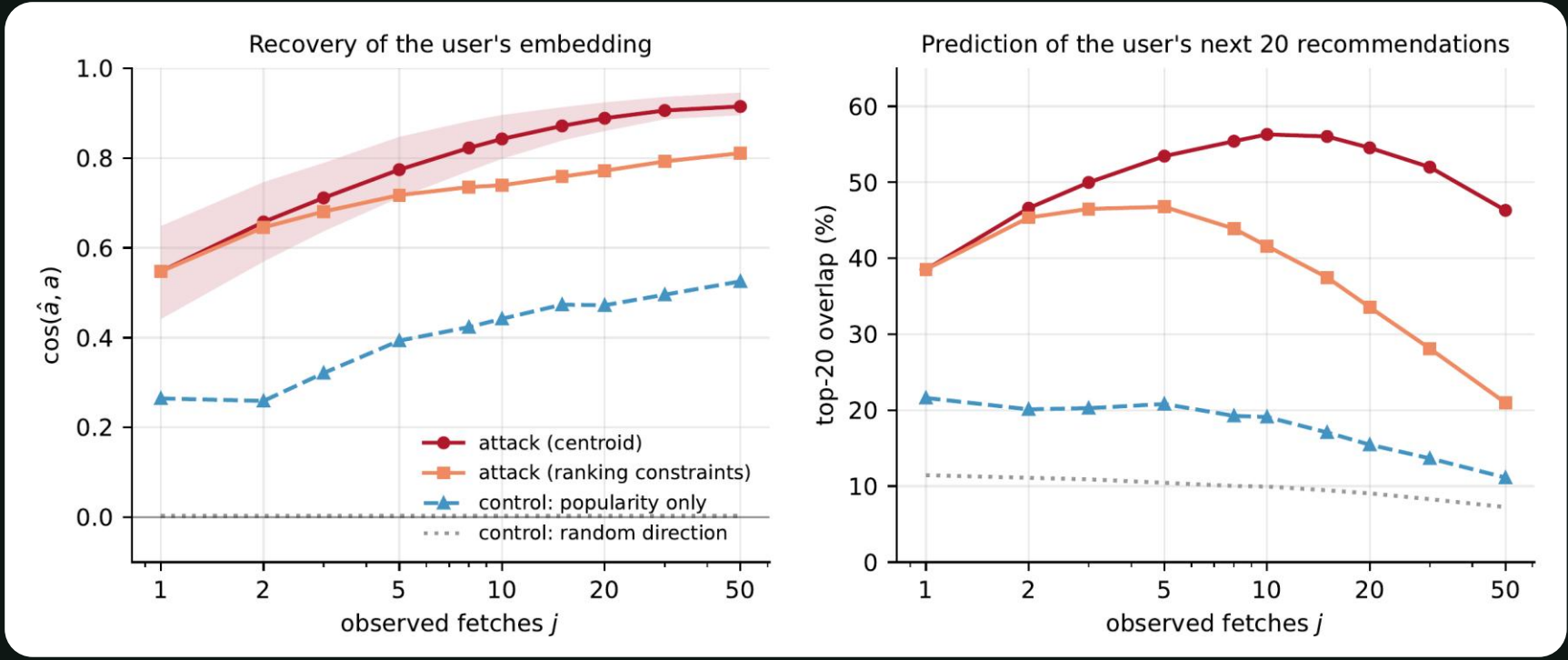
01 B is public, so every item has a position everyone can see.

02 Your recommendations are the items pointing most nearly the way your secret vector points.

03 So each fetch an observer sees is a direction near yours, not one bit.

Schematic. The real item space has 16 dimensions.

The attack



Data bench/results/leakage_attack.jsonl · all 943 users · F1

0.55

cosine with your true vector after one fetch

0.84

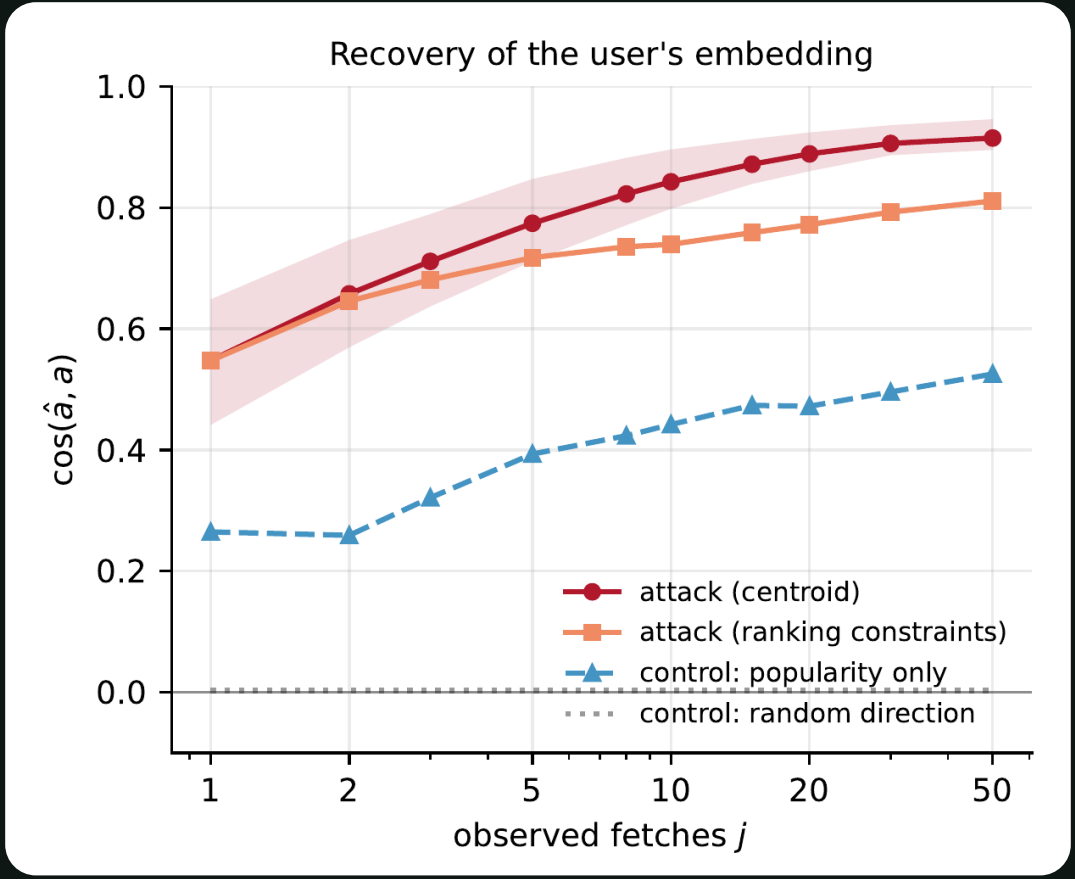
after ten fetches

56%

of your next twenty recommendations, predicted from those ten

The observer sees only which items you fetched. No ratings, no scores.

The control



Data leakage_attack.jsonl · F1, left panel

0.84

the attack, ten fetches

0.44

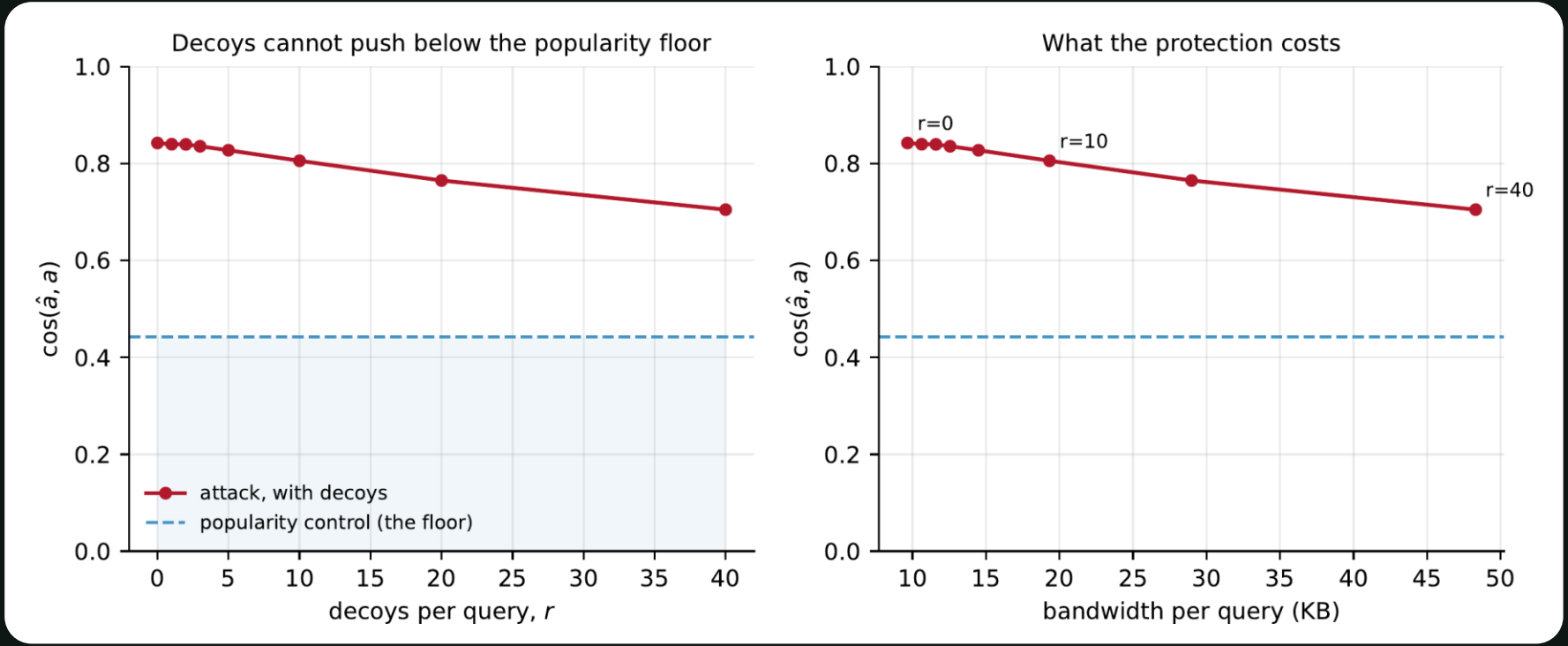
the same method on the ten most popular items, ignoring the user

0.40

the margin: what is learned about you, not about what is popular

The margin is 0.28 after one fetch and 0.38 to 0.42 from two to fifty. A random direction scores 0.003.

Defence one: decoys



Data leakage_attack.jsonl · popularity-weighted decoys, k = 10 · F6

40 decoys

five times the real traffic

0.71

the attack after them, from 0.84

0.44

the floor a working defence must reach

Popular decoys pull the estimate toward what is popular, which the control already knew.

Defence two: differential privacy

$$v \leftarrow (U^T U + E)\, v$$

Nudge, section 9: power iteration on the Gram matrix plus symmetric Gaussian noise E, shared once through PRF keys, so it costs no communication.

$$\sigma = \sqrt{(2 \ln(1.25 / \delta))} / \varepsilon$$

$\delta = 2^{-40}$ as in Nudge. The paper does not state the scale, so it comes from Analyze Gauss, the result it cites (Dwork, Talwar, Thakurta, Zhang, STOC 2014).

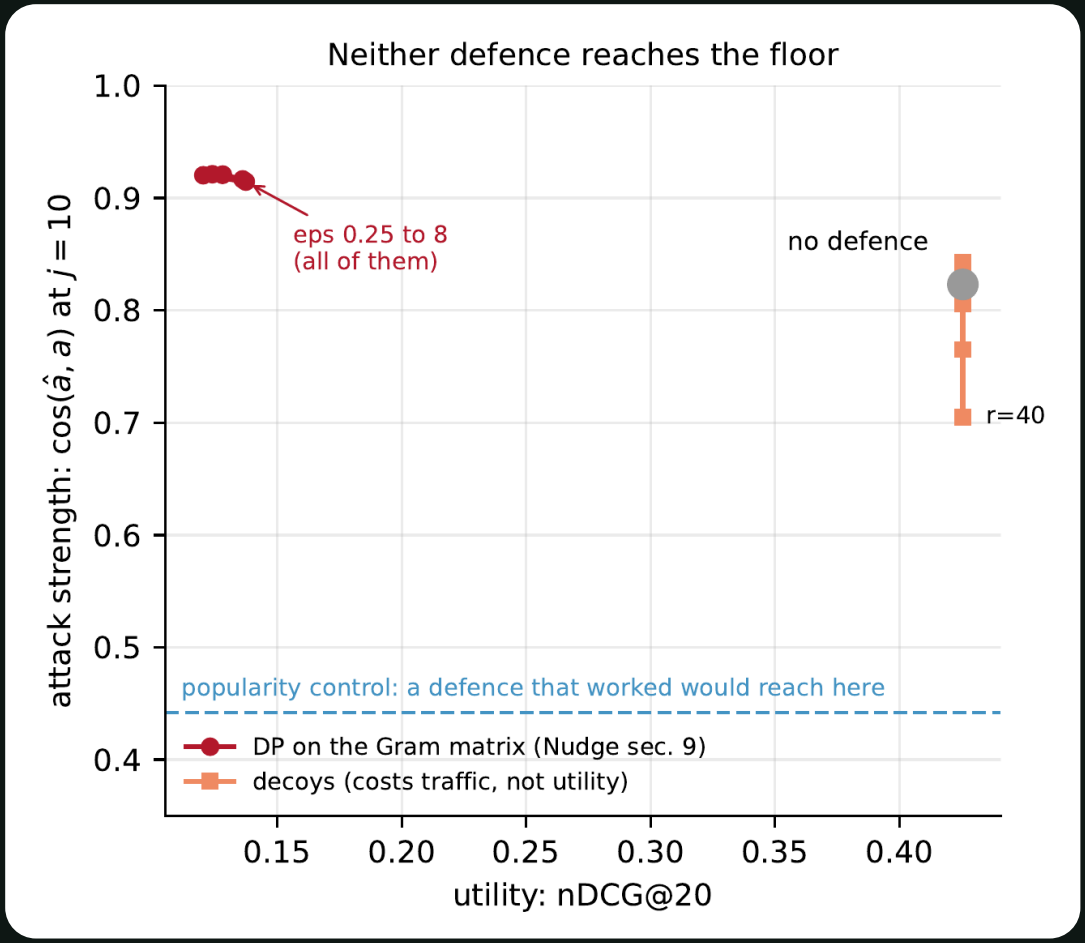
ONE DELIBERATE CHANGE

Nudge divides each user's row by the number of ratings. That bounds a row's norm by 5 / √c, which is above one for anyone with fewer than 25 ratings. We normalise rows to unit length instead, which makes the bound exact, and report both versions.

200 of 943

users in our training split have fewer than 25 ratings

Why it fails



Data dp_study.jsonl · ε = 1, δ = 2^-40 · F10, left

−71%

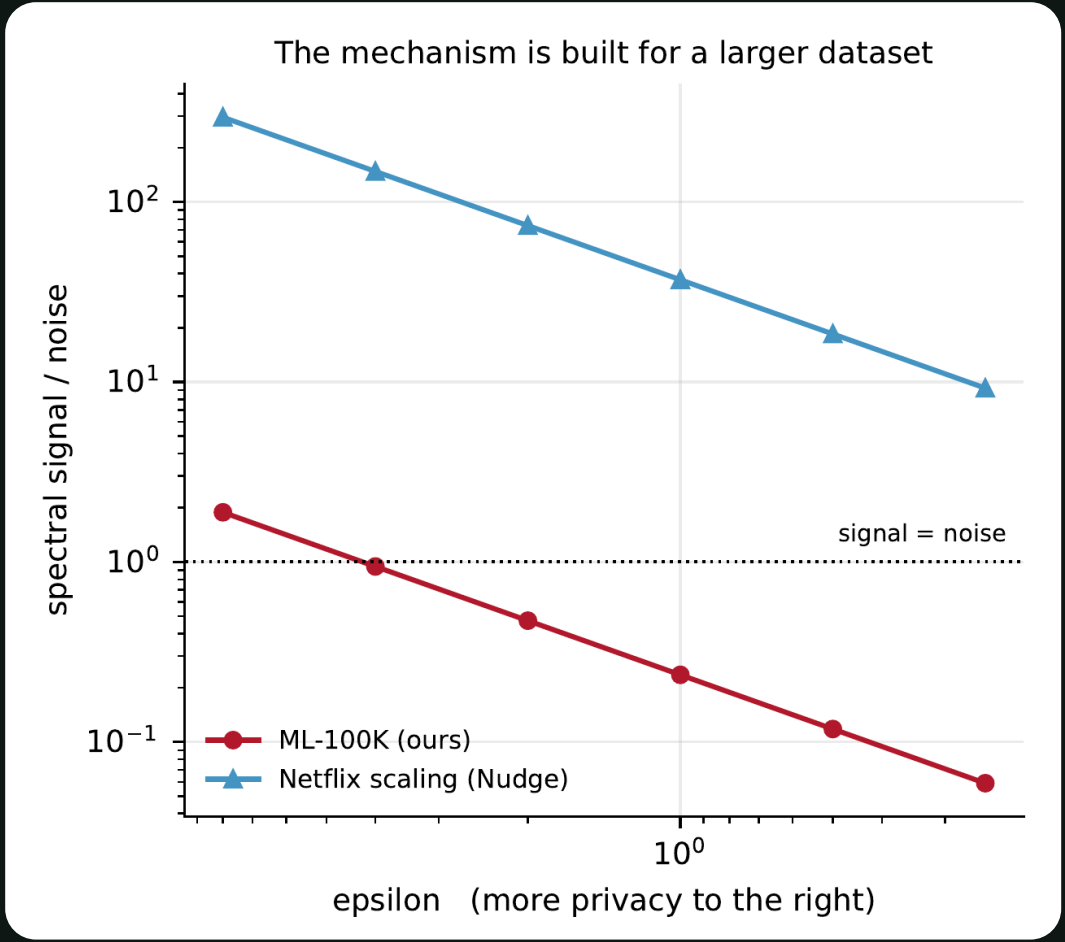
recommendation quality at ε = 1: nDCG@20 from 0.4255 to 0.1239

0.82 → 0.92

the attack gets stronger, not weaker

Differential privacy bounds what B reveals about other people's ratings. The attack uses B as a known map, and you and the observer share the same noisy B.

Why we lose 71% and Nudge loses 17%



Data dp_study.jsonl · F10, right

signal grows with m, the number of users
noise grows with σ√n, n the number of items

157×

larger m / √n for Netflix (480,189 users, 17,770 items) than for MovieLens-100K (943, 1,682)

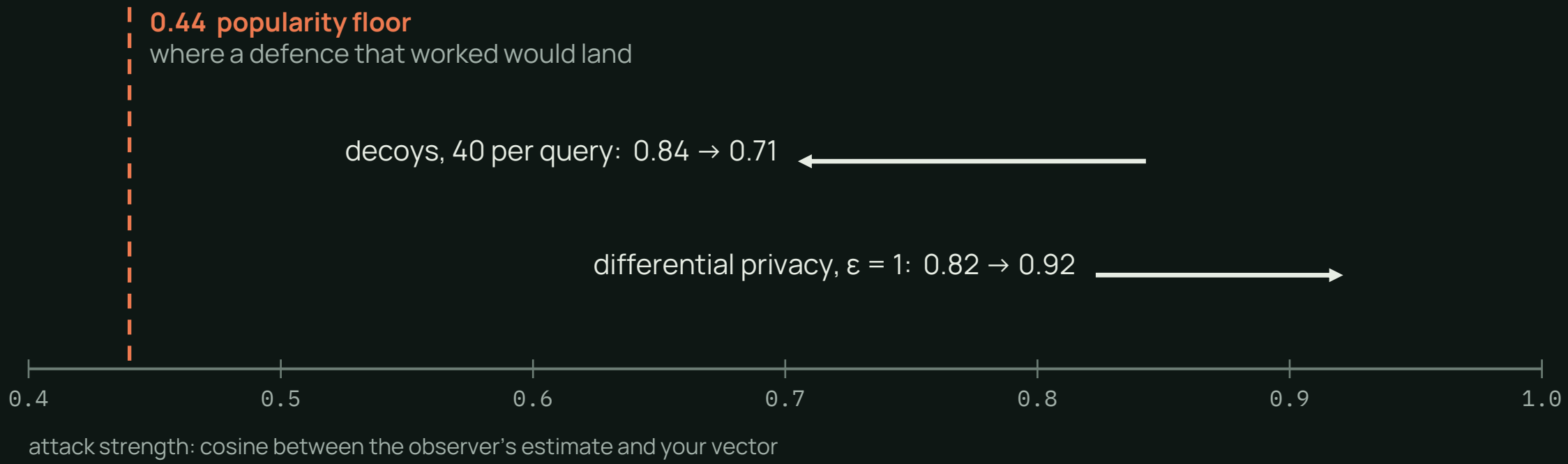
4.2×

noise over signal on our data at ε = 1

0.29 → 0.24

Nudge on Netflix, the same mechanism

So the fetch must be private



Neither defence comes near the floor. A private read leaves the observer no index to average, which is what OblivRec does.

A DPF we can trust

7.16×10^9

comparisons of the DPF's output against the true point function. Every one correct.

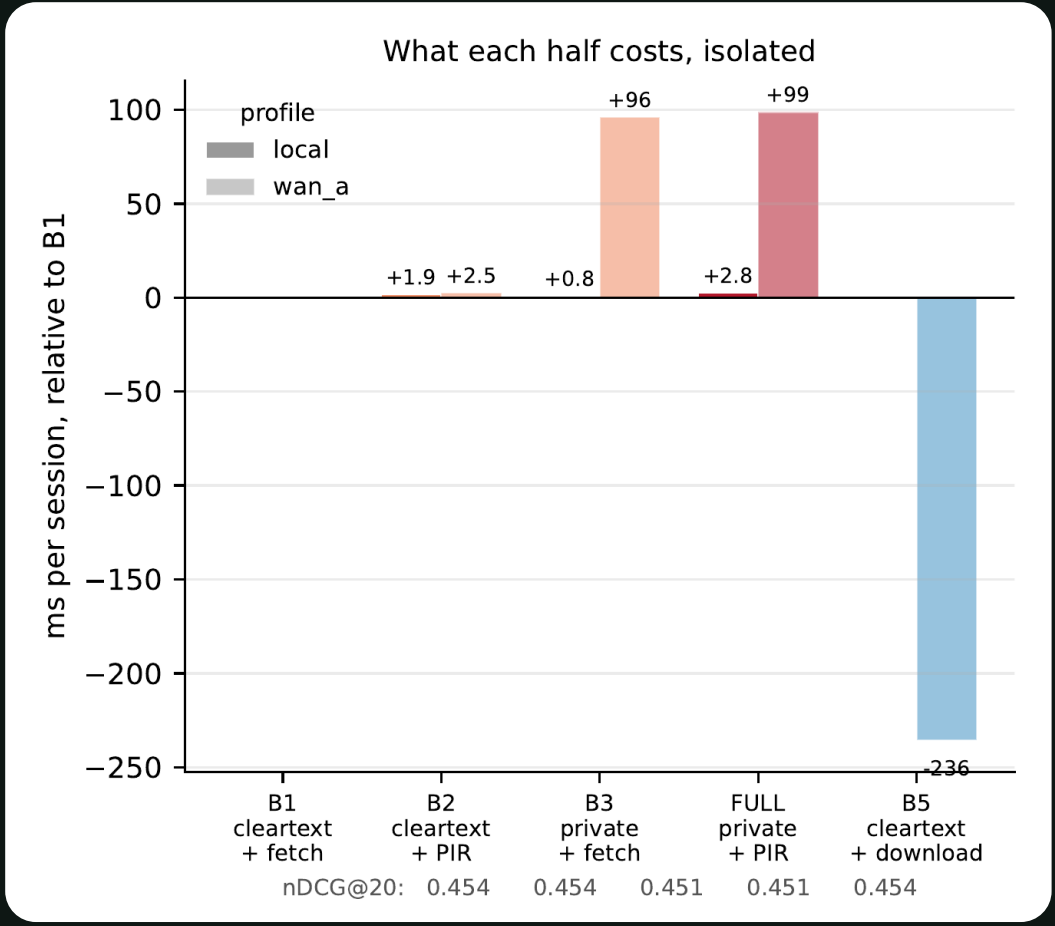
Every secret index against every input, for every domain up to 16 bits on the 64-bit ring and 15 bits on the 128-bit ring. Written from the Boyle, Gilboa and Ishai papers, not taken from a library.

ASSERTED AT EVERY NODE OF THE TREE

On the path to α	seeds differ, control bits differ
Off the path	seeds equal, control bits equal

A wrong control-bit update shows here at the exact level where it happens, long before any output goes wrong.

The cost of each half



Data bench_compose.jsonl · F8, left

FULL = B2 + B3 − B1

to the byte: 64,760,124 bytes, asserted before any row is written

+2.5 ms

private delivery, per session

+96 ms

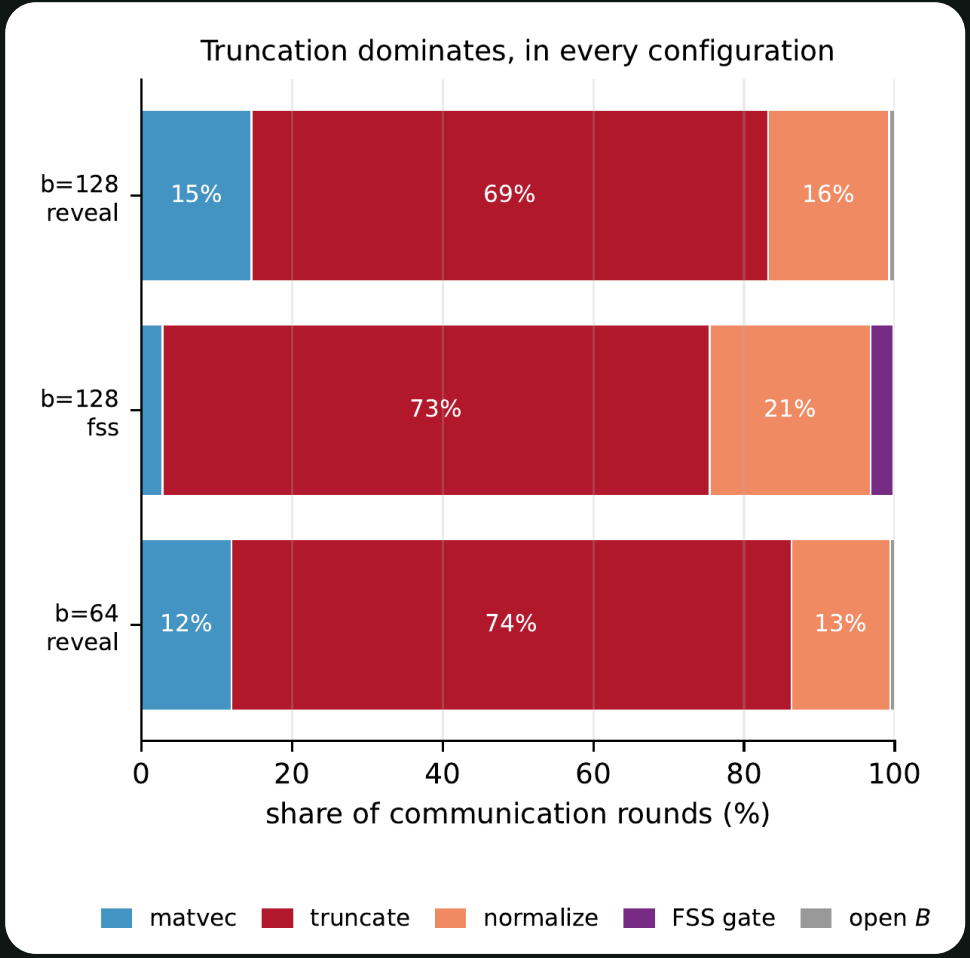
private training, per session, one run shared by 943 users

0.454 → 0.451

nDCG@20

`wan_a: 30 ms round trip, 100 Mbit/s, channel-level emulation`

Where the rounds go



Data bench_stages.jsonl · F9, left

69 to 74%

of all rounds are truncation, in every configuration

3.1%

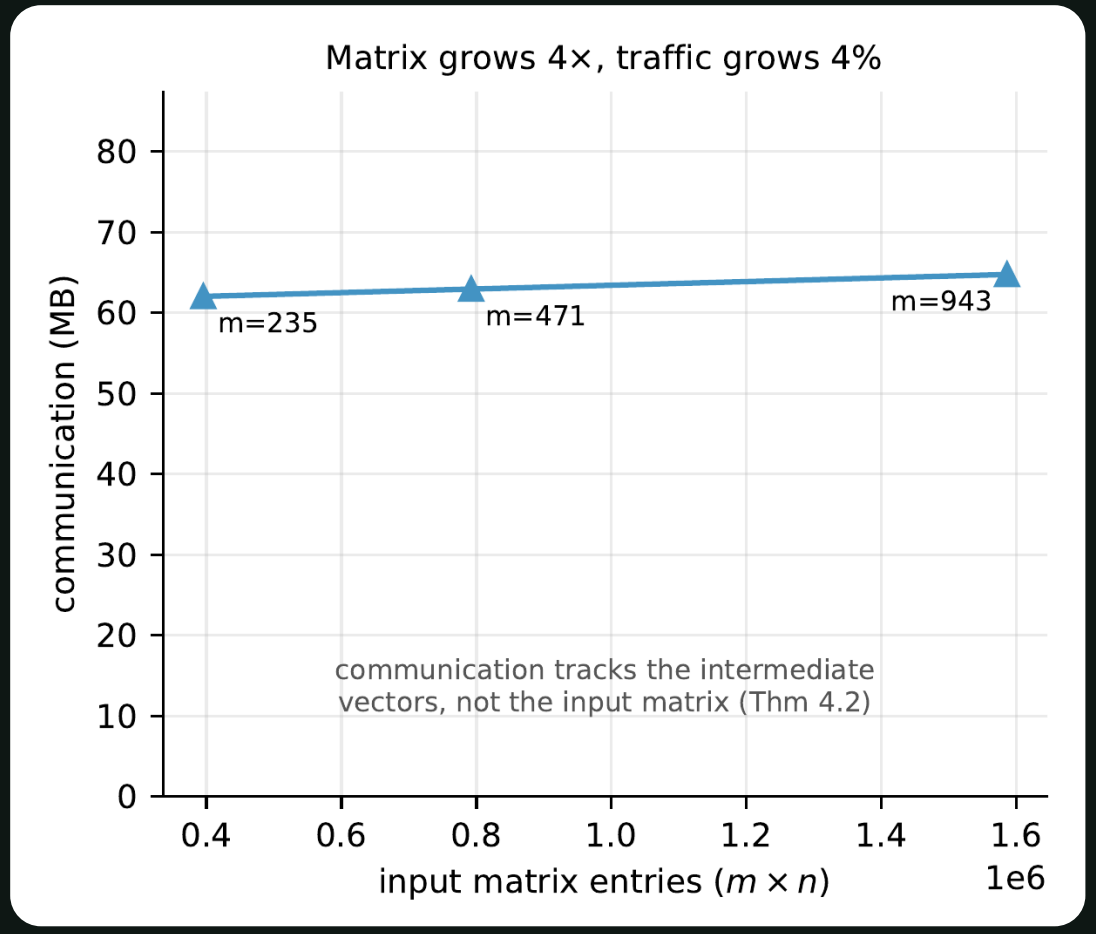
the FSS comparison gate, in the one configuration that has it

0 and 0

rounds and bytes left unexplained by the breakdown

To make training faster, make truncation cheaper. The sophisticated part is not the bottleneck.

The theorem, measured



Data bench_sweep.jsonl · F7, right

4×

larger input matrix, from 235 to 943 users

+4.4%

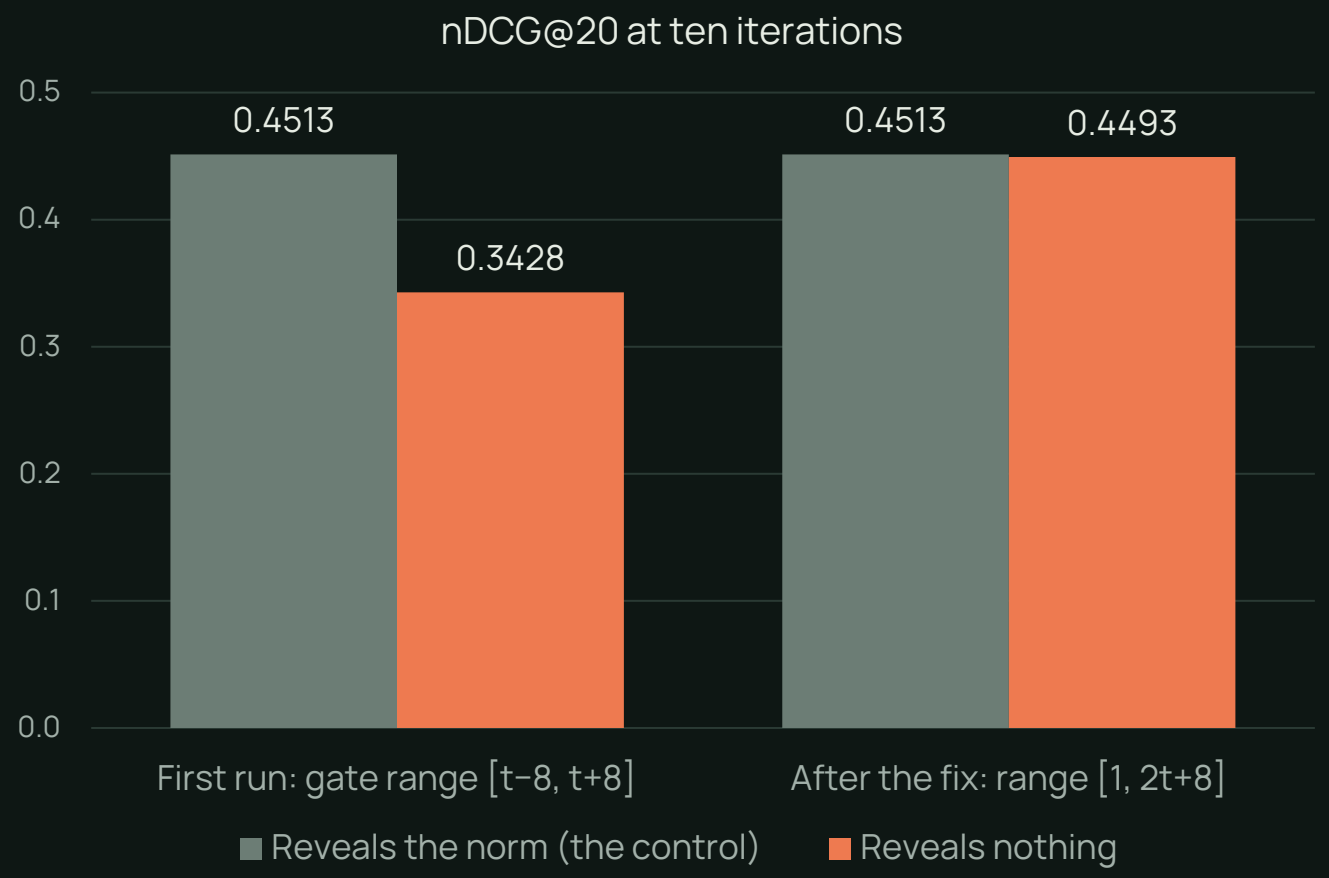
traffic, from 62.03 to 64.75 MB

2,686

rounds, at every matrix size

Communication follows the vectors in the computation, not the rating matrix. That is Nudge's Theorem 4.2, and the reason we built on it.

What measuring quality found



identical

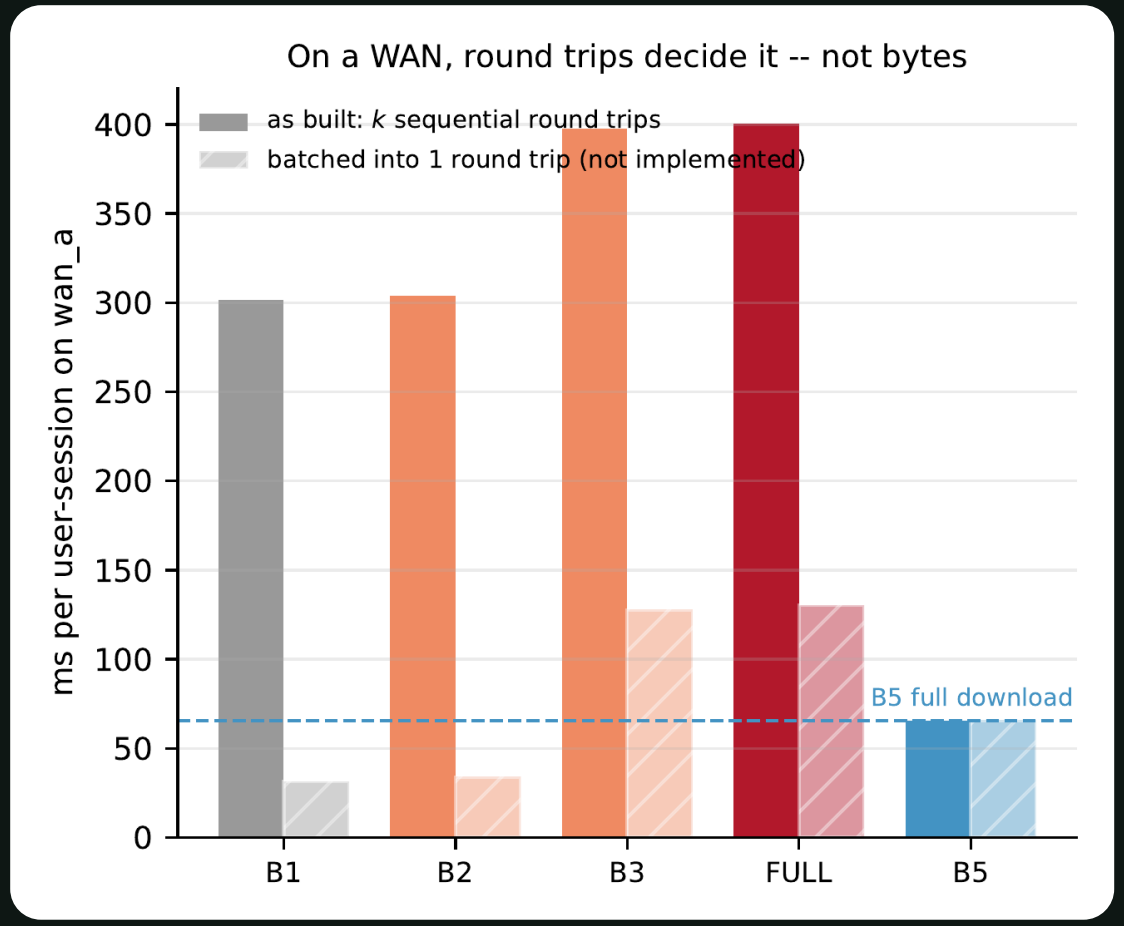
rounds and bytes under both ranges: 11,519 rounds, 143,941,376 bytes. A cost-only benchmark could not see the bug.

0.0020

the real cost of revealing nothing, after the fix

The first run's values are recorded in commit d2138ad and at the gate's call site, not in the committed data.

The result that goes against us



Data bench_compose.jsonl · wan_a · F8, right

4.6×

faster to download the whole catalogue on wan_a: 65.6 ms against 303.9 ms for our private retrieval

45×

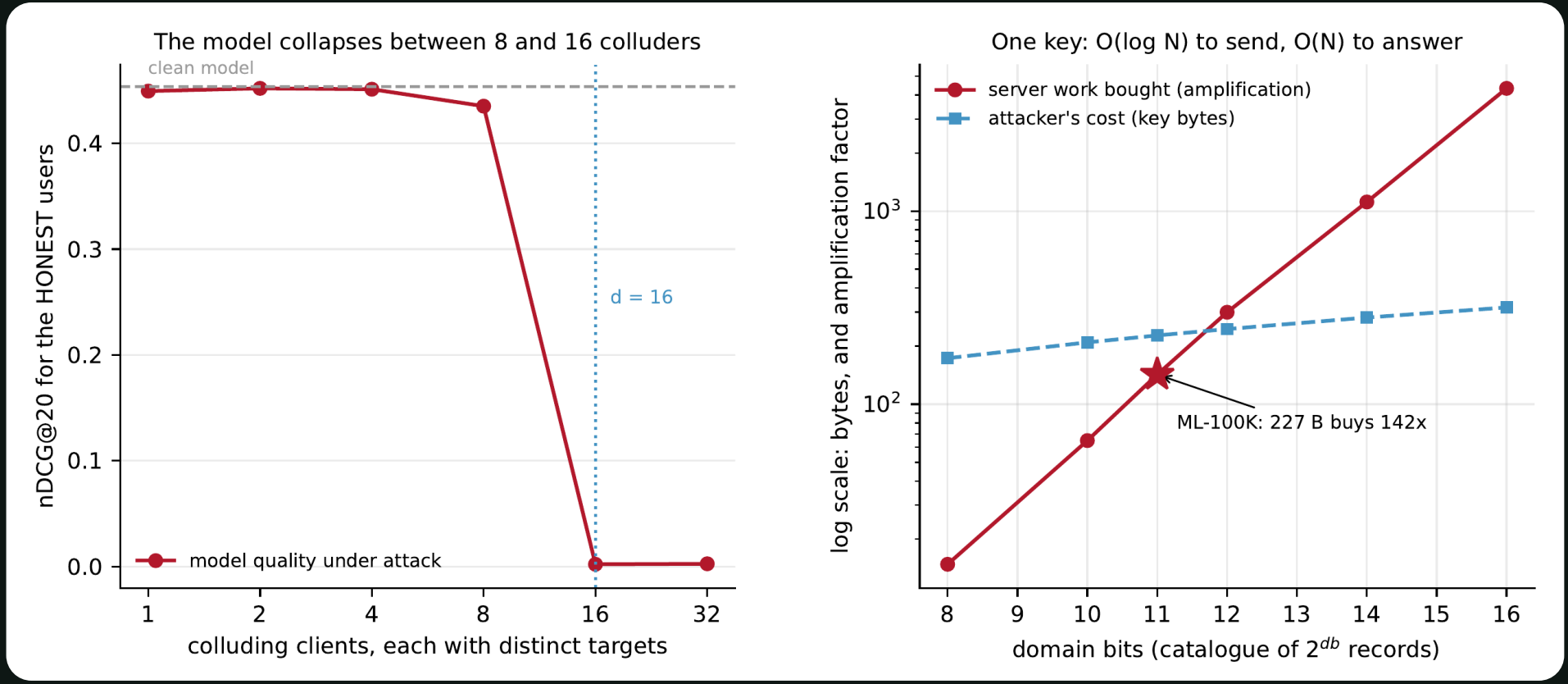
more bytes for the download

33.9 ms

batched private retrieval, one round trip. Not built.

We fetch ten items one after another, so we pay ten round trips. The download pays one.

The malicious client

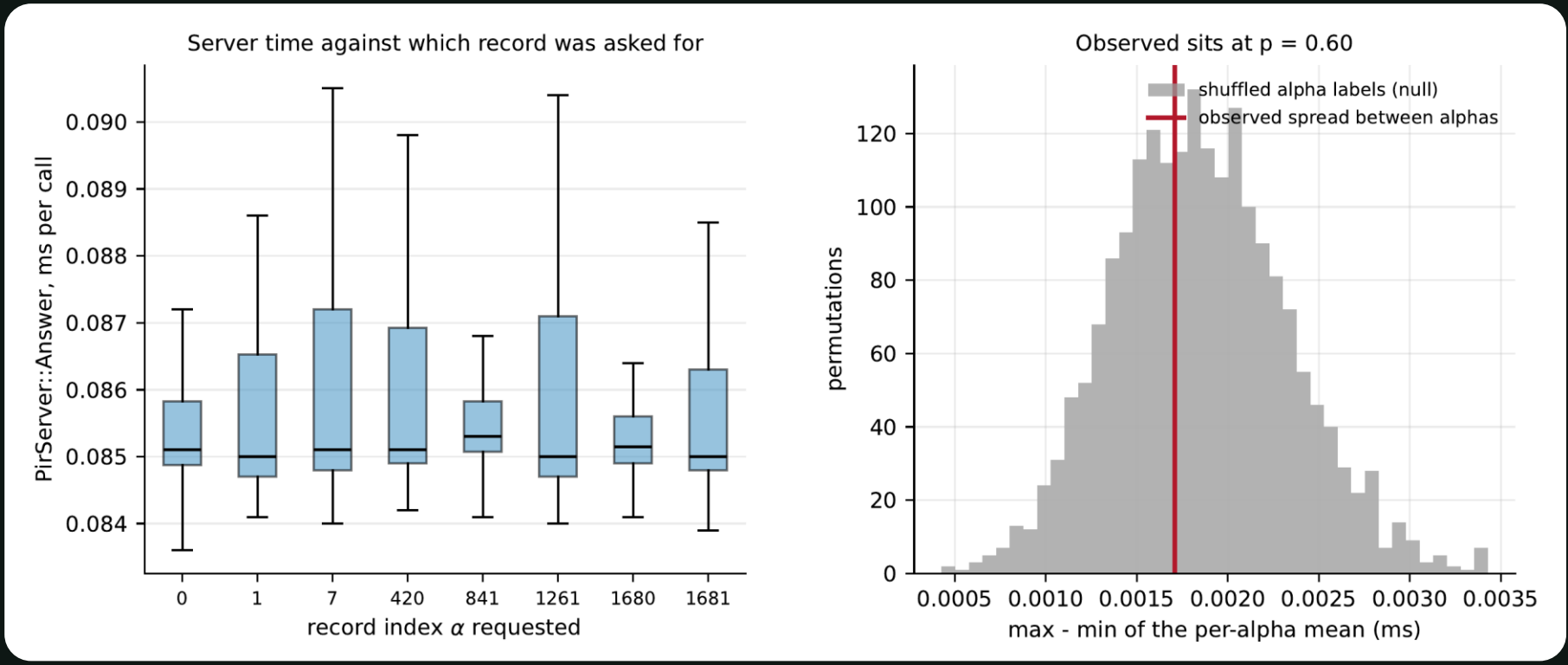


Data poison_study.jsonl, bench_dos.jsonl · F11

Sixteen colluders take nDCG@20 from 0.4536 to 0.0021. Only powers of two were run, so the collapse lies between 8 and 16. The fix costs one round per query.

One 227-byte key buys 142× its own cost in server work in this run, over 100× in every run. Measured, not mitigated.

Timing



≤ 2%

of an 87 µs call: the bound on any record-dependent timing

p = 0.60

permutation test on shuffled labels

Data bench_timing.jsonl · 8 records, 200 interleaved calls each · F12

The spread between records, 1.7 µs, is smaller than the noise within one record, 6.0 µs. A bound, not a proof of constant time.

What we do not claim

TWO SERVERS	**If two of the three servers collude, they learn everything. The whole system rests on this assumption.**
DEVIATION	A server that deviates from the protocol is out of scope.
SCALE	MovieLens-100K only. Three parties in one process did not fit MovieLens-1M in memory.
NETWORK	Wide-area times come from a cost model on measured traffic, not from real networks.
PROOF	The security argument is a simulation sketch, not a formal proof.
TIMING	Absolute times drift with the laptop’s thermal state, so we report ratios.

Conclusion

01 Composing private training and private delivery costs exactly the sum of the halves.

02 Private delivery is not optional. Ten fetches reveal most of your taste, and both cheaper defences fail.

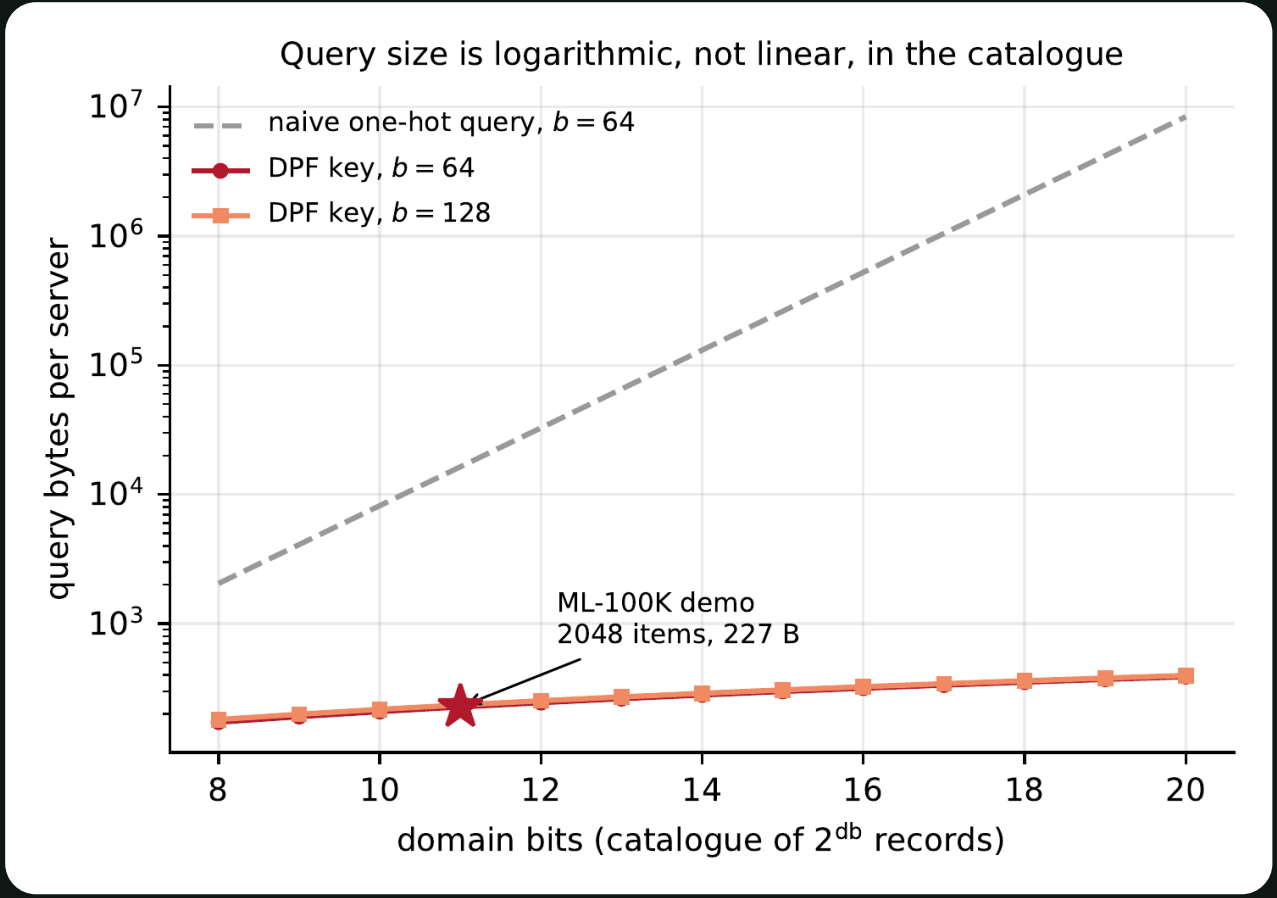
03 About seventy percent of the cost is truncation. That is where to optimise.

Thank you

Shravan Agrawal · Shrasti Dwivedi · Mainak Sarkar

Source, report and the data behind every figure are in the submission, tag v1.0-final.

Query size is logarithmic in the catalogue



227 B

per key at 2,048 records, 64-bit ring

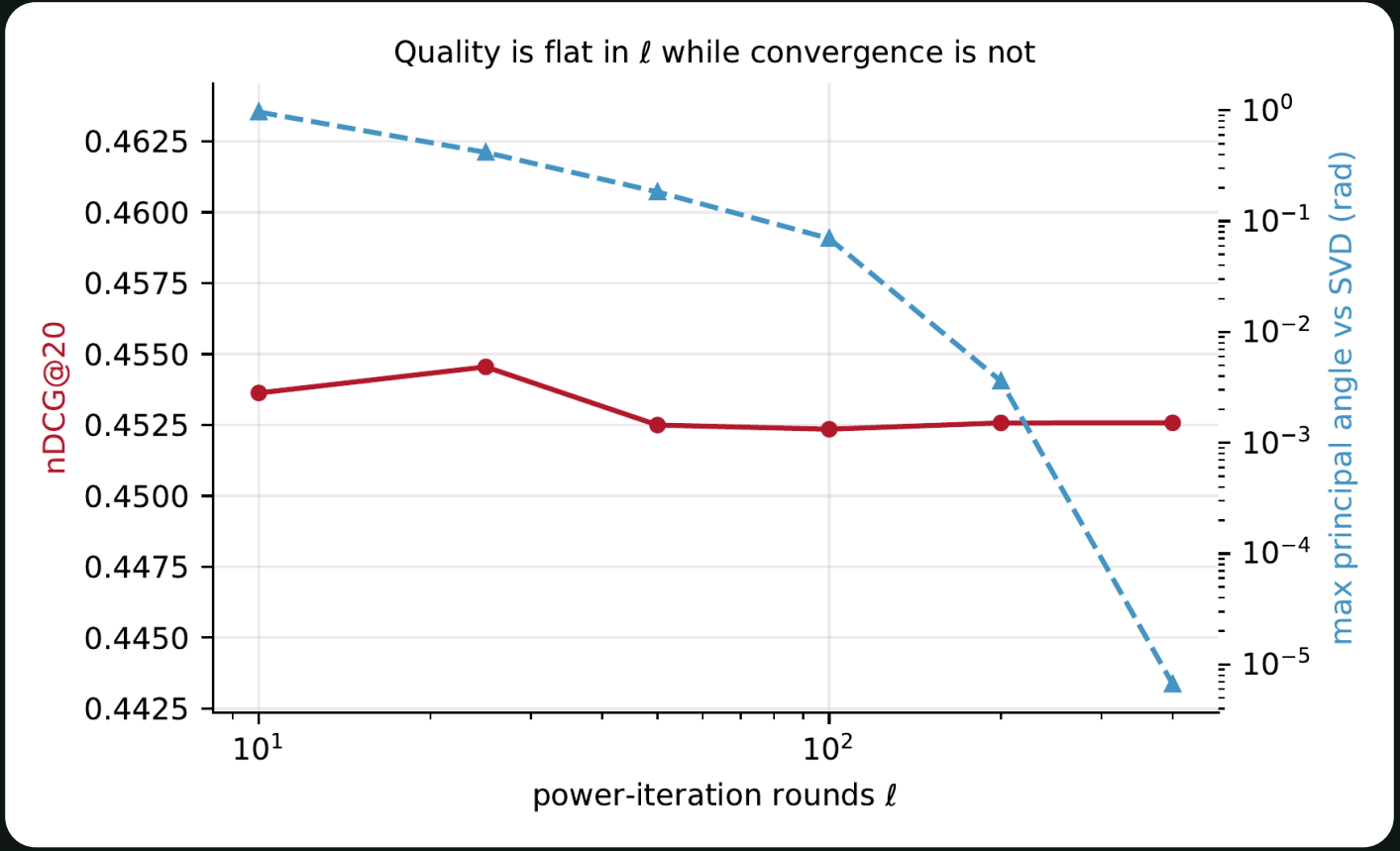
16,384 B

the naive one-hot query

`1 + 4 + 16 + 18 · D + b / 8 bytes, for a domain of D bits`

`Closed form asserted by tests/test_dpf_serialize.cpp · F2`

Quality is flat in the number of iterations



Data oracle_ell_sweep.jsonl · F4

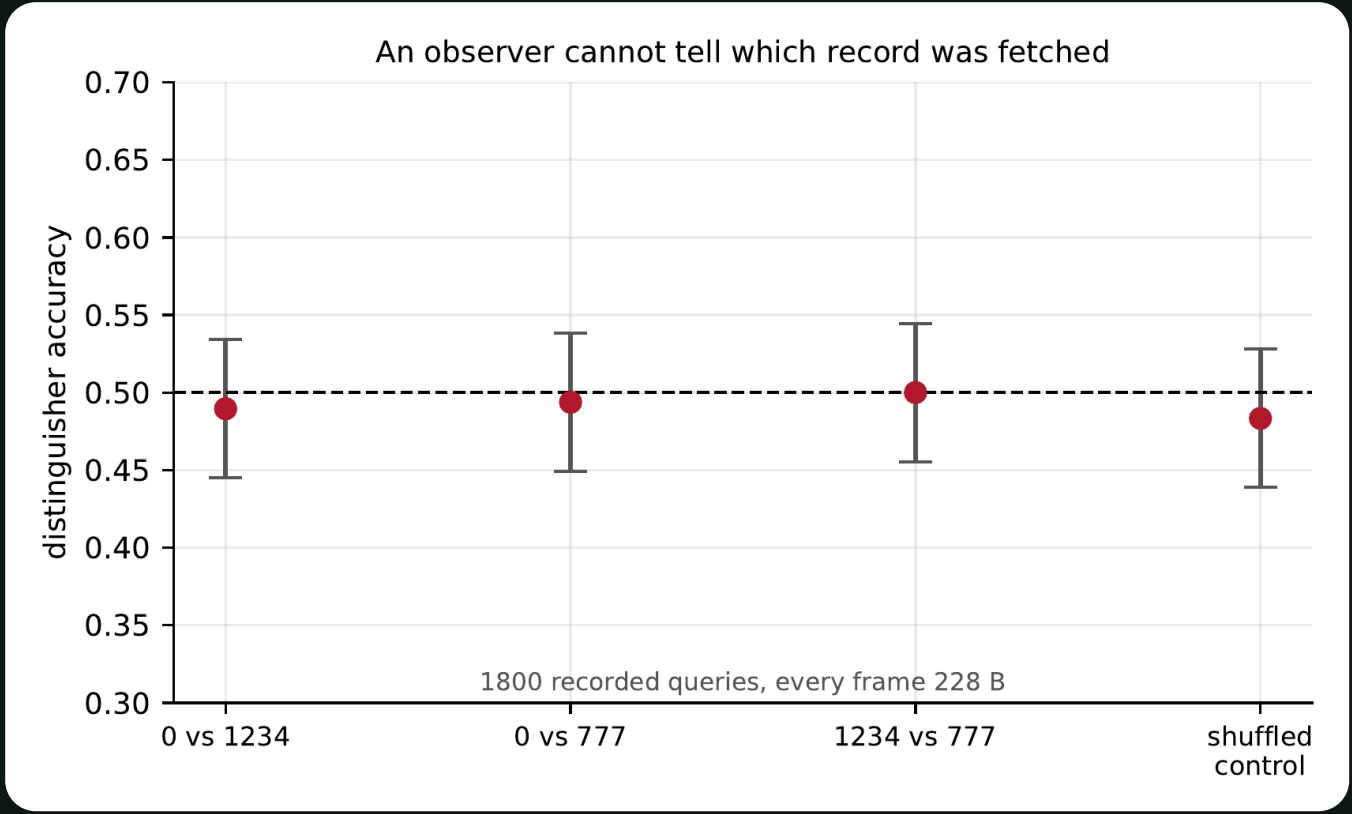
0.4523 to 0.4545

nDCG@20 from 10 to 400 iterations

$0.97 \rightarrow 6.7 \times 10^{-6}$

radians to the true subspace

A classifier on the wire bytes sits at chance



Data distinguisher_result.jsonl · F5

228 B / 265 B

every query frame and every reply, whatever the index, over 1,800 queries

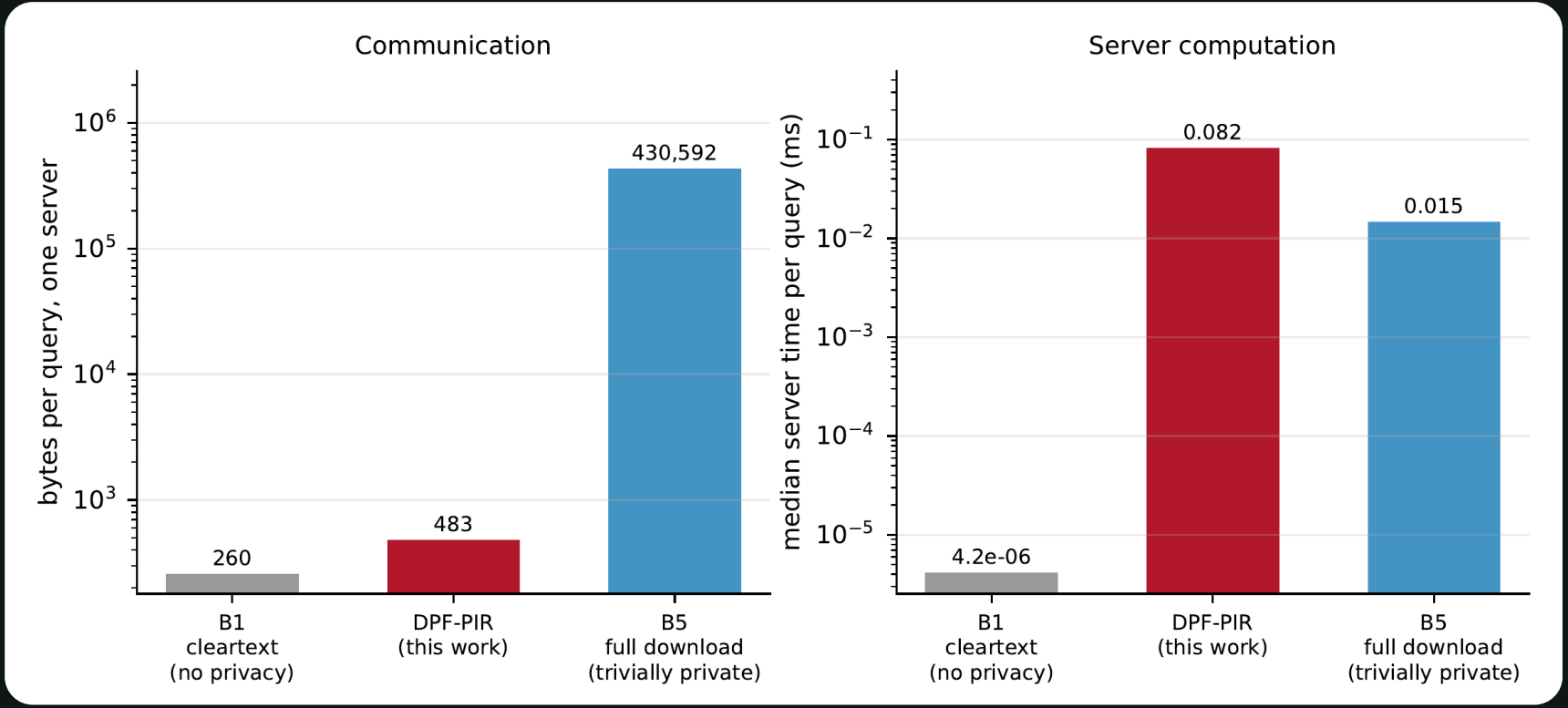
0.490 to 0.500

classifier accuracy, with 0.5 inside every 95% interval

0.483

the same pipeline on shuffled labels

The private read against its alternatives



Data bench_baseline.jsonl · F3

446×

fewer bytes than the full download, both servers

about 5×

more server CPU than the download

8.0 to 22.9

Gbit/s: the link speed below which the private read wins, across runs

Threat model at a glance

CLASS	ADVERSARY	WHAT WE CLAIM
A1	one semi-honest server	learns nothing beyond the leakage profile, argued by a simulation sketch
A2	one server and colluding users	honest users' ratings stay hidden, model quality does not
A3	two colluding servers	no guarantee: the shares reconstruct
A4	a deviating server	out of scope
A5	a malicious user	weight inflation closed, redistribution and the DoS open
A6	a network observer	sizes fixed and measured, server timing bounded, wire timing not analysed